



Learning Objectives:

1. Explain Scanning Network Concepts.
2. Demonstrate Various Scanning Techniques for host Discovery
3. Demonstrate Various Scanning Techniques for port and Service Discovery
4. Various Techniques for OS Discovery
5. Various techniques for scanning beyond IDS and Firewall

Before Starting note the scanning have mainly three types:

- 1. Port Scanning: determines open ports and services**

TCP/IP or UDP

Three ranges

0-1023 well known ports

1024-49151 Registered Ports

49152-65535 Dynamic range means empty and can be use for attacking purposes

- 2. Network Scanning; identifying ip addresses on a given network or subnet**

Procedure for identifying hosts on a Network!

- 3. Vulnerability Scanning: Discover presence of known weaknesses on target systems**

(CWE: Common Weakness Enumeration)

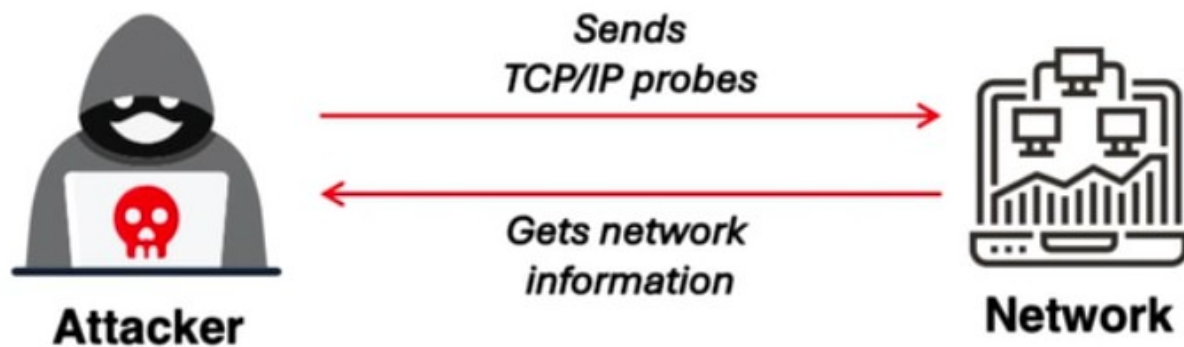
1. Scanning Concepts

A set of procedures used to identify hosts, ports and services in a network. It is the component of information gathering used by attacker to create profile of a target organisation.

Tools:

1. nmap
2. hping3
3. NetScanTools Pro

Process:



Objectives:

- to discover live hosts, ip addresses and open ports of live hosts
- to discover OS and system architecture
- to discover services running on hosts
- to discover vulnerabilities in live hosts

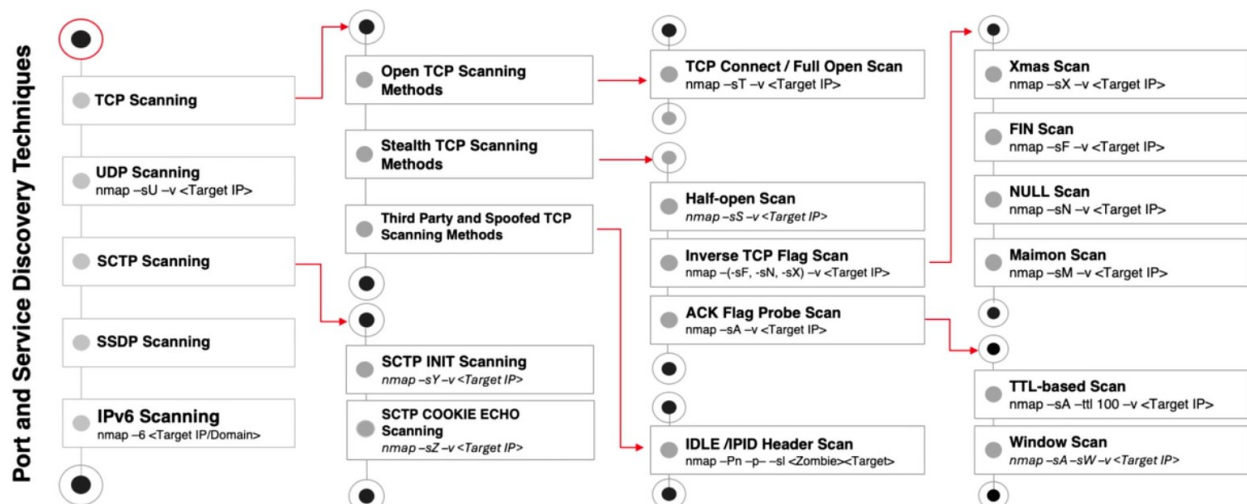
the main point here is we do packet crafting like we send tcp headers having flags like PSH ,URG, FIN, SYN, ACK and RST

on the basis of these flags we control the reaction of the targeted device....

3. Scanning Techniques for PORTS

Port Scanning Techniques

The port scanning techniques are categorized according to the type of protocol used for communication



1. Full-Open Scan

it is detected when a port is open after completing the three way handshake. It establishes a full connection and then closes the connection by sending an RST packet

Command: nmap -sT -v <targetIP>

2. Stealth Scan(My Fav One):

it involves abruptly resetting the TCP connection b/w the client and server before the completion of three way handshake signals, thus leaving the connection half-open.

Attacker use this technique to bypass firewall rules as well as logging mechanisms, and hides himself under the appearance of regular network traffic.

Command: nmap -sS -v <targIP>

Note: XMAS scan uses multiple flags at a time like xmas tree having multiple lightning

Now lets move towards Service discovery

Its a binary application that running in the background of a system ie like printing service etc.... It doesn't have any interface

Command: nmap -sV <targIP>

-sV= service

its detection helps attackers to obtain info about running services and their versions on a target system. Obtaining an accurate service version number allpws attackers to determine the vulnerability of the target system to particular exploits.

4. Techniques for OS Discovery

Its part of an idea called banner grabbing.

It's a method used to determine the OS running on a remote target system. There are two types

- **Active Banner Grabbing:** Specially crafted packets are sent to the remote OS and the responses are noted. The responses are then compared with a db to determine OS.
- **Passive Banner Grabbing:** Error messages can provide info about the type of server, type of OS and SSL tool used by the target remote system. Secondly we can capture network traffic and analyze them to determine the OS used by the remote system. 3Rdly looking for the extension in the URL ie .aspx= IIS server and Windows Platform

It actually allows an attacker to determine the vulnerabilities possessed by the system and the exploits that might work on a system to further carry out additional attacks.

Command: nmap -O <targIP>

nmap --script smb-os-discovery.nse <targIP>// it gives the OS and Computer Name.

We can also use TTL to identify the OS on the target device. Ie for windows TTL=128, Linux TTL=64

5. Scanning Beyond IDS and Firewall

Though firewalls and IDSs can prevent malicious traffic from entering a network, but attacker can manage to send the intended packets to the target by Evading them through the following techniques:

- **Packet Fragmentation:** refers to splitting of a probe packet into several smaller packets while sending it to a network. Its not new scanning method but a modification of the previous techniques. Its simple: Fragment the TCP Header so that the packet filters are not able to detect what the packets are untended to do.

Command: `nmap -sS T4 -A -f -v <targIP>`

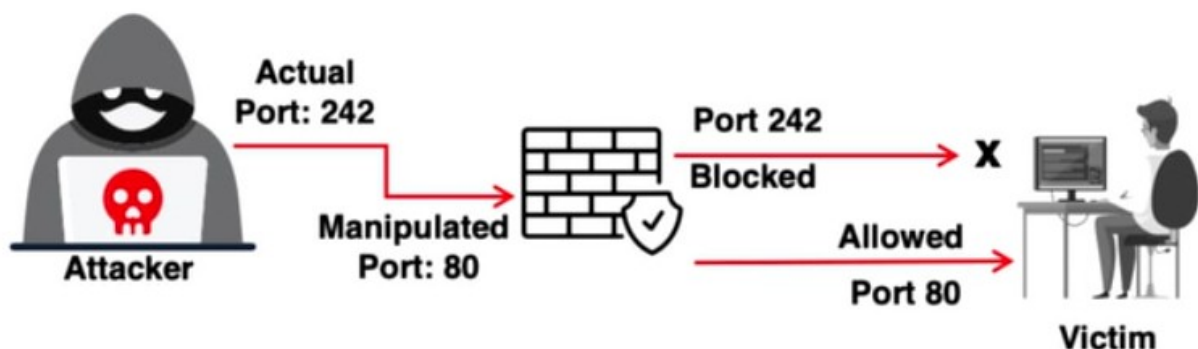
T4=aggressive Scan, -A=everything, -f=fragments, -v=verbose

- **Source Routing:**
- **Source Port Manipulation:** refers to manipulating actual port number with common port numbers in order to evade a firewall or IDS. It occurs when a firewall is configured to allow packets from well-known packets like HTTP, DNS, FTP, etc

Command: `nmap -g 80 <targIP> // -g = grave or`

`nmap --source-port 80 <targIP>`

Thus firewall allowing the manipulated to the victim from the attacker



- **IP address Decoy:** refers to generating or manually specifying the IP addresses of decoys in order to evade an IDS/firewall. It appears to the target that the decoys as well as the hosts are scanning the network. This technique makes it difficult for the IDS/firewall to determine which IP address was actually scanning the network and which IP addresses were decoys.

Commands: **Method#1:** `nmap -D RND:10 <targIP>`

Method#2: `nmap -D decoy1,decoy2,decoy3`

- **IP Address Spoofing**

- **MAC Address Spoofing**
- **Creating Custom Packets:** tools like colasoft, Packet Builder, NetScanTools Pro can craft packets to bypass the IDS/firewall
- **Randomizing Host Order and Sending Bad Checksums:** Attacker scan the number of hosts in the target network in random order to scan an intended target that is behind a firewall. **Command: nmap --randomize-hosts <targIP>.** Attacker can also send packets with bad or bogus TCP/UDP checksums to the intended target to avoid certain firewall rule sets. **Command: nmap --badsum <targIP>**
- **Proxy Servers**
- **Anonymizers**

Compiled By GH057